

Matriz de Permisos

PyME Financing Platform - Documento tecnico de autorizacion y acceso

1. Objetivo

Definir de forma precisa que puede hacer cada rol dentro del sistema. Esta matriz debe usarse para implementar guards, middleware, validaciones de backend y visibilidad en frontend.

Regla central

La seguridad real debe vivir en el backend. Ocultar botones en el frontend mejora la experiencia, pero no sustituye la validacion de permisos antes de consultar, crear, actualizar, subir archivos o ejecutar procesos.

2. Roles del sistema

Rol	Descripcion	Alcance general
internal_operator	Usuario interno de la empresa que opera la herramienta.	Puede gestionar el proceso completo: empresas, solicitudes, revision documental, analisis, matching, productos, reglas y auditoria.
applicant	Usuario solicitante de credito.	Puede registrar su empresa, crear solicitudes, cargar documentos y consultar el estado/resultados permitidos de sus propios expedientes.

3. Principios de autorizacion

Principio	Regla
Propiedad de datos	Un applicant solo puede acceder a empresas donde companies.applicant_user_id apunte a su usuario.
Flujo interno	Si companies.applicant_user_id es NULL, el caso puede ser operado internamente por internal_operator.
Procesos sensibles	Calcular riesgo, generar matching, revisar documentos y administrar productos son acciones exclusivas de internal_operator.
Auditoria	Cambios relevantes deben registrar user_id, accion, entidad, fecha y datos controlados.
Documentos	El applicant solo puede subir/consultar documentos de solicitudes propias. No puede aprobar ni rechazar documentos.

4. Matriz de permisos por modulo

Modulo	Accion	internal_oper ator	applicant	Validacion backend
Autenticacion	Iniciar sesion	Si	Si	Credenciales validas y usuario activo.
Autenticacion	Cerrar sesion	Si	Si	Invalidar sesion/token del lado cliente y respetar expiracion.
Usuarios	Crear usuario internal_operator	Si	No	Solo operador interno; para MVP puede ser seeder/manual.
Usuarios	Crear usuario applicant	Si	Si	Registro publico o creado por operador, segun flujo.
Usuarios	Desactivar usuarios	Si	No	No borrar fisicamente si hay actividad.
Empresas	Crear empresa	Si	Si	Si applicant crea, asignar applicant_user_id. Si operador crea, applicant_user_id puede ser NULL.
Empresas	Ver empresas	Todas	Solo propias	Filtrar por applicant_user_id para applicant.
Empresas	Editar empresa	Si	Solo propia	Evitar cambios criticos si solicitud esta closed, salvo regla de reapertura.
Solicitudes	Crear solicitud	Si	Si	company_id debe pertenecer al applicant o ser operada internamente por operador.

Modulo	Accion	internal_oper ator	applicant	Validacion backend
Solicitudes	Ver solicitudes	Todas	Solo propias	Propiedad via company.applicant_user_id.
Solicitudes	Cambiar estado	Si	No	Respetar transiciones validas.
Documentos	Cargar documento	Si	Solo propio	Validar propiedad, tipo, tamano, nombre seguro y hash.
Documentos	Revisar documento	Si	No	Registrar reviewed_by_user_id y reviewed_at.
Documentos	Descargar documento	Si	Solo propio	No servir archivos por ruta directa sin validar permisos.
Productos	Crear/editar producto	Si	No	No borrar si ya tiene matches; usar is_active.
Reglas	Crear/editar regla	Si	No	Validar rule_field, operator, valores y score_weight.
Analisis	Calcular riesgo	Si	No	Verificar precondiciones y guardar input_snapshot.
Matching	Generar recomendaciones	Si	No	Requiere risk_assessment_id valido.
Expediente	Ver expediente completo	Si	Propio limitado	El applicant ve solo su expediente y campos permitidos.
Auditoria	Ver audit_logs	Si	No	No mostrar valores sensibles en claro.

5. Reglas por endpoint critico

Endpoint / operacion	Politica de acceso	Regla de propiedad o negocio
GET /companies	internal_operator: todas; applicant: propias	Applicant filtra por companies.applicant_user_id = user.id.
GET /applications/:id	Ambos roles	Applicant solo si la solicitud pertenece a una empresa propia.
PATCH /applications/:id/status	internal_operator	Validar maquina de estados.
POST /documents/:id/upload	internal_operator o applicant propietario	Validar archivo antes de guardar y registrar metadatos.
PATCH /documents/:id/review	internal_operator	Requiere documento uploaded y registra revision.
POST /risk-assessments	internal_operator	No ejecutar si hay datos financieros incompletos o deuda no confirmada.
POST /matches	internal_operator	Debe existir risk_assessment_id; no ligar matches solo a application_id.
GET /audit-logs	internal_operator	Enmascarar datos sensibles si old_values/new_values existen.

6. Casos especiales

Caso	Decision recomendada
Empresa creada por operador sin solicitante	Permitir companies.applicant_user_id = NULL, pero conservar created_by_user_id o datos de contacto.
Solicitud cerrada	Bloquear ediciones criticas. Si se requiere cambio, implementar reapertura controlada por internal_operator.
Documento rechazado	Permitir nueva carga sobre el mismo application_document o reemplazar archivo, manteniendo auditoria.
Producto desactivado	No usarlo para nuevos matches, pero conservarlo visible en historiales antiguos.
Regla desactivada	No aplicarla a nuevos matches. El historial se conserva por input_snapshot y rule_set_version.

Anexo de Actualización

PyME Financing Platform

Documento base conservado: Matriz de Permisos

Este anexo no reemplaza ni resume el documento base. El contenido original se conserva íntegro. Las reglas de este anexo se agregan al diseño y prevalecen cuando una regla anterior sea ambigua o use lenguaje de sugerencia.

A. Decisiones confirmadas para todos los documentos

Decisión	Instrucción obligatoria
Registro de applicant	El applicant debe poder crear su propia cuenta desde una ruta pública usando, como mínimo, fullName, email y password. El sistema debe asignar el rol applicant automáticamente.
Resultado visible para applicant	El applicant no debe ver el análisis interno completo, risk_score, pesos de reglas, DSCR detallado, audit_logs ni comparación interna de productos. Solo debe ver la decisión final publicada por el operador.
Operación interna	El internal_operator debe ver risk_assessments, application_matches, razones internas, porcentajes, indicadores financieros y debe crear/publicar la decisión final.
Corrección de necesidad	El internal_operator debe poder validar o corregir la necesidad declarada por el applicant mediante validated_need_type antes de generar matching o decisión final.
Documentos rechazados	Cuando el applicant suba nuevamente un documento rechazado, el sistema debe reemplazar el archivo en el mismo application_document, actualizar metadatos, cambiar status a uploaded y registrar audit_log.
Auditoría	El sistema debe auditar solo acciones sensibles; no debe registrar absolutamente todos los cambios ni guardar secretos, tokens, password_hash o contenido de documentos.

B. Regla de redacción para implementación

Toda frase del documento base que use “recomendado”, “sugerido”, “podría” o “si se implementa” debe interpretarse como instrucción obligatoria cuando describa una regla del MVP, una validación de seguridad, una entidad de base de datos, un endpoint crítico, una transición de estado o una prueba mínima.

C. Permisos agregados

Acción	internal_operator	applicant	Validación backend
Registrarse como applicant	No aplica	Sí	Ruta pública crea usuario con rol applicant; no permite elegir rol.
Validar/corregir necesidad	Sí	No	Solo operador. Registrar validated_need_type y audit_log.
Ver risk_assessments	Sí	No	Applicant no accede al análisis interno.
Ver application_matches internas	Sí	No	Applicant no ve porcentajes ni comparativas internas.
Crear decisión final	Sí	No	Debe existir risk_assessment válido.
Publicar decisión	Sí	No	Cambia is_published_to_applicant y published_at.
Ver decisión publicada	Sí	Solo propia	Applicant solo si la decisión pertenece a su solicitud y está publicada.
Reemplazar documento rechazado	Sí	Solo propio	Actualizar mismo registro y auditar replace_document.